



THINKST
SCAPES

Q1 • 2024

<https://thinkst.com/ts>

Brought to you by



**Most companies find out way too late
that they've been breached.**

Thinkst Canary changes this.

Canaries deploy in under 4 minutes
and require 0 ongoing admin overhead.

They remain silent until they need to chirp,
and then, you receive that single alert.

When.it.matters.

Find out why some of the smartest security teams
in the world swear by Thinkst Canary.

<https://canary.love>

Contents

Introduction	2
Themes covered in this issue	3
Revealing more than anticipated, and preventing prying eyes	4
PrintListener: Uncovering the Vulnerability of Fingerprint Authentication via the Finger Friction Sound	5
ModelGuard: Information-Theoretic Defense Against Model Extraction Attacks	6
RECORD: A REception-Only Region Determination Attack on LEO Satellite Users	7
Private web search with Tiptoe	8
Can Virtual Reality Protect Users from Keystroke Inference Attacks?	9
Backtrace in Time: Revealing Attackers' Sleep Patterns and Days Off in RDP	10
Brute-Force Attacks with Calendar Heatmaps	
Taking another look with a fresh perspective	11
Breaking HTTP Servers, Proxies, and Load Balancers Using the HTTP Garden	12
Compiler Backdooring For Beginners	13
Revisiting 2017: AI and Security, 7 years later	14
Automated Large-Scale Analysis of Cookie Notice Compliance	15
Turning Windows into doors	16
LSA Whisperer	17
Wishing: Webhook Phishing in Teams	18
Misconfiguration Manager: Overlooked and Overprivileged	19
Smoke and Mirrors: How to hide in Microsoft Azure	20
Nifty sundries	21
Backdoor in XZ Utils allows RCE: everything you need to know	22
More Money, Fewer FOSS Security Problems? The Data, Such As It Is	23
MUDding Around: Hacking for gold in text-based games	24
DeGPT: Optimizing Decompiler Output with LLM	25
Conclusions	26

*Cover photo: Baobabs at Lekhubu Island, Sua Pan, Botswana.
Image by Daniel de Villiers (Thinkst)*



A lookout point in Knysna Forest.
Photo by Bradley Jayanath (Thinkst)

Introduction

Welcome to the Q1, 2024 edition of ThinkstScapes! This issue focuses on content released, published, or presented between the first of January and the end of March, 2024.

Quarter 1 showed a decline in the pace of publications, with only a few marquee conferences taking place.

While there were still some true gems published in this quarter, we expect the community to pick up as we move towards the end of university terms and into the summer.

As a reminder: if you are aware of work we've missed, a blog post we should have seen or a conference we should have covered, we'd love to hear about it. Please send them to ts@thinkst.com!

In addition to over 1,200 blog posts, this quarter's content was drawn from the following conference presentations:

Conference name	Number of talks
NDSS	268
ShmooCon	47
SO-CON	16
ChiBrrCon	21
CactusCon	25
Real World Crypto	44
Sunshine Cyber Conference	55
Open Confidential Computing Conference	30
IT-Defense	12
Disobey	26
Securi-Tay	20
Ringzer0 BOOTSTRAP	13
USENIX Security	82
Total	659

Themes covered in this issue

REVEALING MORE THAN ANTICIPATED, AND PREVENTING PRYING EYES

This theme explores novel techniques to extract more information about a target than the target was expecting. We look at: some sci-fi acoustic side-channels to recover characteristics of fingerprints from audio, passive geo-location of satellite devices, VR keystroke recovery, and the patterns-of-life of attackers. On the positive side, there's private web search and a novel defence for ML-as-a-service providers to prevent attackers from making off with their IP.

TAKING ANOTHER LOOK WITH FRESH PERSPECTIVES

Here we revisit existing assumptions or theory with a new point of view. There are: differential analyses of HTTP servers, revisiting Reflections on Trusting Trust, a look back at the last seven years of AI and security, and analysis of GDPR compliance.

TURNING WINDOWS INTO DOORS

The works in this theme explore abusing functionality within the Microsoft ecosystem to create security complications. Look for new ways to hitch a ride on Microsoft SCCM, hiding in Azure, or ways to ask the LSA service to reveal things it shouldn't. Finally, there's a blog on trading Azure tokens up to send phishing messages in Teams.

NIFTY SUNDRIES

As always, there's great work that just doesn't fit into this quarter's themes. Look for some good coverage on the XZ backdoor debacle, security analysis of funding open-source, bypassing the restrictions on restricted shells, and improving decompilation output with LLMs.

*Pink blossoms on a tree in Berlin.
Image by Vittoria Tosso (Thinkst)*

Revealing more than anticipated, and preventing prying eyes

- ✓ *PrintListener: Uncovering the Vulnerability of Fingerprint Authentication via the Finger Friction Sound*
- ✓ *ModelGuard: Information-Theoretic Defense Against Model Extraction Attacks*
- ✓ *RECORD: A REception-Only Region Determination Attack on LEO Satellite Users*
- ✓ *Private web search with Tiptoe*
- ✓ *Can Virtual Reality Protect Users from Keystroke Inference Attacks?*
- ✓ *Backtrace in Time: Revealing Attackers' Sleep Patterns and Days Off in RDP Brute-Force Attacks with Calendar Heatmaps*

*A distant view of Table Mountain.
Image by Riaan Snijman (Thinkst)*

PrintListener: Uncovering the Vulnerability of Fingerprint Authentication via the Finger Friction Sound

Authors: Man Zhou, Shuao Su, Qian Wang, Qi Li, Yuting Zhou, Xiaojing Ma, and Zhengxiong Li

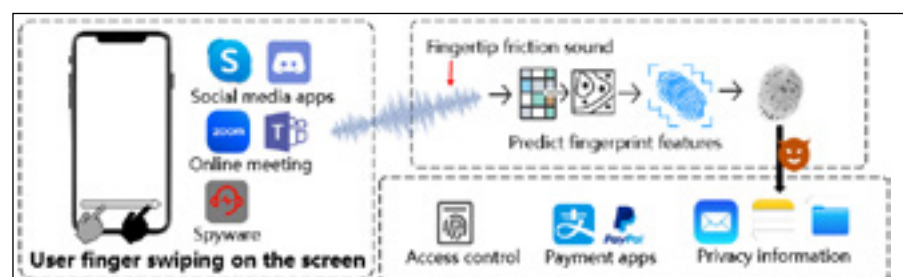


This work used signal processing and machine learning to recover fingerprint features from an acoustic side-channel. By recording the sound of a target swiping on a mobile device (in different ambient noise levels), the researchers were able to determine the high-level fingerprint pattern (left and right loops and whorls) with almost 90% accuracy. After determining the high-level pattern, minutiae of the fingerprint was inferred using a neural network, further boosting overall knowledge about the target fingerprint. Combining these inferred characteristics with synthesised “master prints” the researchers could generate candidates that would match fingerprints from the population almost 10% of the time in five attempts.

TAKEAWAYS:

- ✓ **The sensitivity of modern microphones** on phones and computers is impressive. As opposed to legacy GSM voice, IP and VoLTE audio provide a much higher bandwidth channel, allowing more of the acoustics to pass to listeners. These acoustics can include background noise and audio from outside the range of human hearing, providing more information for recovery. The fidelity of these sensors and channels put at risk a wide-number of biometrics.
- ✓ **While the overall chances** of your fingerprint being successfully stolen from this approach are still small, it's important to consider when using biometrics for access to extremely sensitive locations. Biometrics offer ease-of-use benefits, though they are almost impossible to change if compromised.

Figure 1. A high-level diagram of the attack scenario for the PrintListener research.



ModelGuard: Information-Theoretic Defense Against Model Extraction Attacks

Authors: Minxue Tang, Anna Dai, Louis DiValentin, Aolin Ding, Amin Hass, Neil Zhenqiang Gong, Yiran Chen, and Hai Li



[Paper](#)



[Code](#)

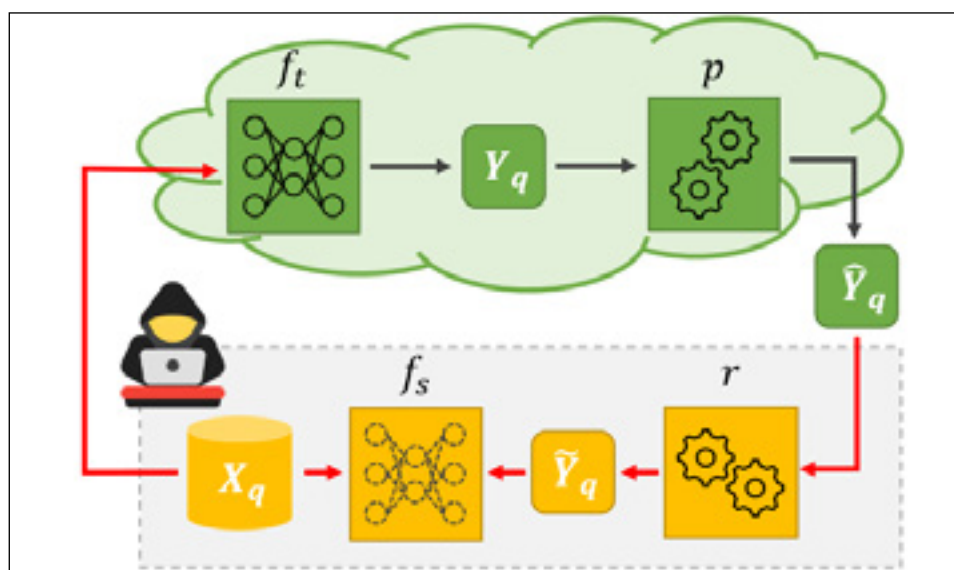
This work looked at defending against model extraction attacks. Model extraction attacks happen when an attacker queries an ML-as-a-service (MLaaS) vendor with the goal of copying their model and weights. There have been existing research efforts into the defence against these IP-stealing attacks, attempting to balance performance of the protected MLaaS' outputs with their utility in bootstrapping a model. The authors propose two new defences: one against a strong attacker model, and one against a weaker attacker. These new defences are compared with the existing state-of-the-art in this field in terms of output accuracy degradation, performance of an extracted model, and computational performance.

The stronger of the two defences proposed, ModelGuard-S performs at the top of the field, and only incurs a minor runtime performance degradation. ModelGuard-S works by quantising (i.e., rounding) the prediction to a fixed area surrounding the result of the first prediction of that label. By creating these fixed-size prediction spaces (within a chosen ϵ), there is a limit on how much information can be obtained close to a decision boundary. On a larger image recognition model, ModelGuard-S was able to reduce the extracted model's accuracy to at most 55% correct inference, while keeping the original model's accuracy. For less powerful attacks, the extracted model's accuracy was much closer to 10%.

TAKEAWAYS:

- ✓ **While still at the scale** of smaller image recognition models, these attacks highlight the risks to intellectual privacy for MLaaS providers.
- ✓ **It is still early days** for this game of cat and mouse, but it appears to be only a matter of time until a few thousand dollars of LLM API access could be used to bootstrap a clone-model with similar performance.

Figure 2. A high-level diagram of a model extraction attack with a permutation defence (p).



RECORD: A REception-Only Region Determination Attack on LEO Satellite Users

Authors: Eric Jedermann, Martin Strohmeier, Vincent Lenders, and Jens Schmitt

 [Code](#)

 [Paper](#)

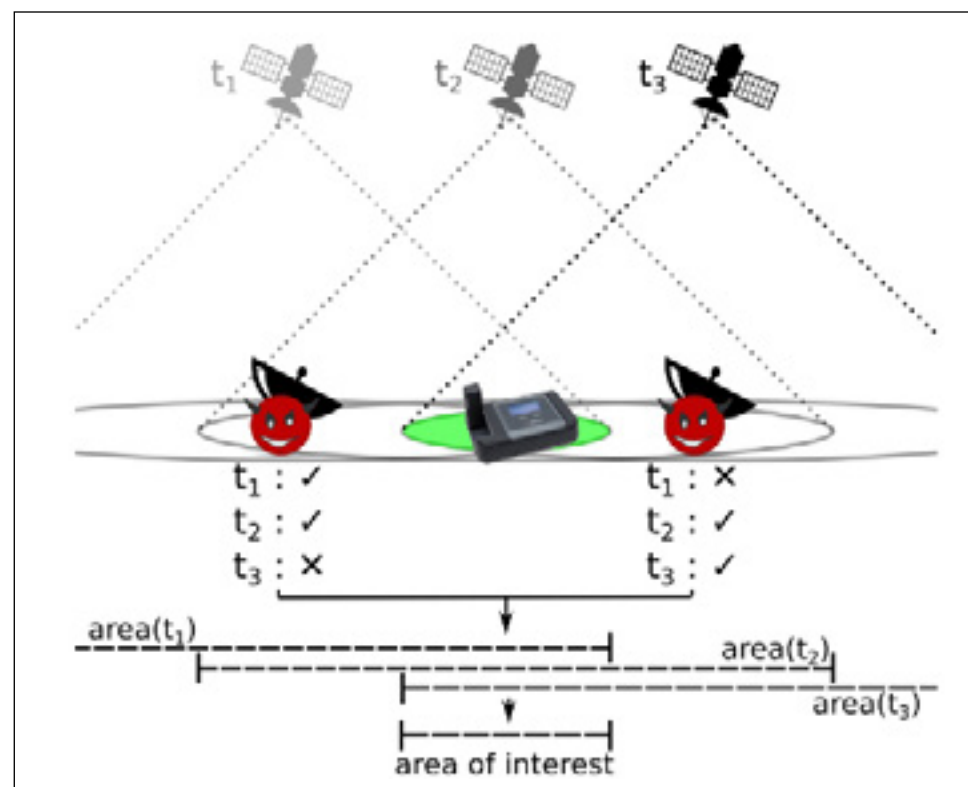
This work explored passively geolocating devices that communicate with a satellite network that has satellites in low Earth orbit (LEO). These satellites are always moving relative to the earth's surface, so there are frequent hand-offs between satellites. First, the researchers mapped each beam of each satellite (the satellite's positions are public knowledge) in an area of interest (e.g., Europe) by recording the hand-off messages for an attacker-owned device at a known location. These beam maps were then saved for later use in narrowing-down the possible location of the target device.

Then multiple receivers spread out within the overall beam size (~4000 km for Iridium) to listen for messages addressed to the target device's identifier (which is static – the determination of the identifiers is out of scope for this work). Over the course of multiple hours, by listening to the device hand off between beams, it is possible to narrow down the possible location of the device to approximately a circular region with an 11 km radius. With additional time, this can be further narrowed down, and the researchers explored a more localised process of trying to locate a device by listening to its uplink when within ~30 km of the target.

TAKEAWAYS:

- ✓ **Legacy protocols have a nasty habit** of sticking around for longer than their security shelf-life. Not only must they continue to support older devices, but this work shows that the borrowing of GSM's identification protocol by Iridium allows for privacy leaks due to the unencrypted and static nature of the handshake.
- ✓ **It's likely only a matter of time** until there is a crowdsourced database of satellite devices and their approximate locations. Similar sites exist for Wi-Fi, Bluetooth and other radio devices, and interesting patterns have been found looking at the data in aggregate.

Figure 3. A figure showing how the attack works at a high-level. Using multiple receivers in coordination listening for downlink traffic bound for the target device, the attack can start to determine when a device is in range of a specific satellite beam.



Private web search with Tiptoe

Authors: Alexandra Henzinger, Emma Dauterman, Henry Corrigan-Gibbs, and Nickolai Zeldovich

 [Slides](#)

 [Paper](#)

 [Video](#)

 [Code](#)

This research explores optimisations for private search that prevent search queries being known by the search provider. Search queries can reveal information about the end-user (such as a query about rights as an undocumented worker, or LGBT+ organisations in countries where they are outlawed, etc.) that can violate their privacy if the queries are sold, data-mined, or breached. While there have been advances in fully-homomorphic encryption (FHE), searching millions of documents with FHE would still take far too long.

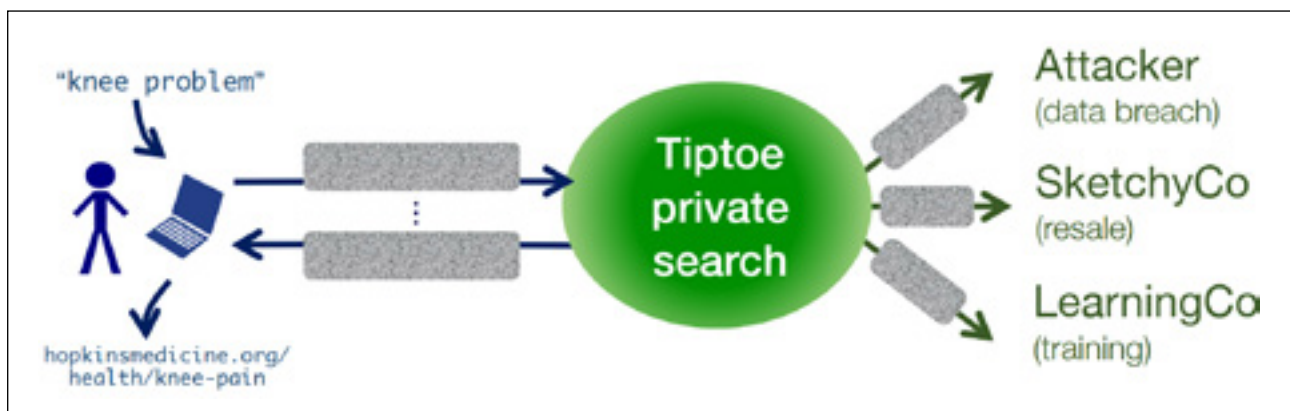
This open-source private search system, Tiptoe, splits the search problem into three separate sub-problems, removing the need for FHE. The first step is performed on the client system, which runs a lightweight embedding of the query, and finding the closest cluster of similar documents. Then, under a lighter encrypted computation model, the clusters were compared with indexed documents on the server, returning a document identifier. Finally, an encrypted lookup of that identifier returns the URL, without the server learning about the query or the returned document URL.

The Tiptoe system still requires more CPU cycles, bandwidth and client storage than non-privacy-preserving search. Tiptoe offers decent results in terms of relevancy, with an overall latency of just under 3s per query. This is orders of magnitude faster than other private search systems, but still has a ways to go to compete with non-private search.

Figure 4. A diagram of how search query information is kept private even against a range of data leaks from the search provider.

TAKEAWAY:

- ✓ **While still a research concept**, the pace of improvements show that it will not be long until there is the technical feasibility for a whole host of private web services. It will help privacy-centric web services (e.g., ProtonMail, Kagi, etc.) provide more confidence to paying users that their data is protected and differentiate themselves from the mainstream user-as-product services.



Can Virtual Reality Protect Users from Keystroke Inference Attacks?

Authors: Zhuolin Yang, Zain Sarwar, Iris Hwang, Ronik Bhaskar, Ben Y. Zhao, and Haitao Zheng

 [Website](#)

 [Paper](#)

This research explored the possibility of performing keystroke-recovery remotely within a VR environment. As VR technologies improve, there are more workplace options to enable remote workers to feel more connected with their teams. These VR headsets contain advanced sensors to track a user's gestures, movements and the surrounding environment. When users are in a multi-user VR environment, some of this sensor data is projected onto the VR environment.

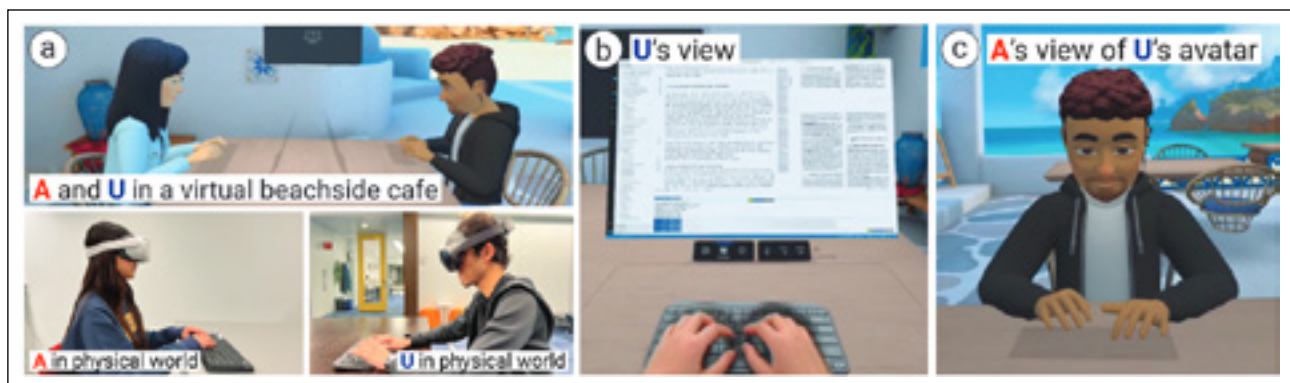
By training a multi-step ML pipeline, the researchers were able to use data from avatar finger movement in the VR environment to recover the contents of what they were typing with almost 80% accuracy. In an experiment with multiple participants, 13 of the 15 participants typed in such a way that allowed for the recovery of the typed text; two of the participants didn't have enough finger motion to correctly recover their keystrokes. Finally, an analysis of how reducing the frequency of updates to the avatar from the sensors (from 60Hz to 6Hz) was performed, showing it rendered the attack infeasible.

Figure 5. A figure of the attack setup, where A has a view of U in a VR environment and is able to recover U's keystrokes from screenshots of the VR environment.



TAKEAWAYS:

- ✓ **It is surprising** that VR headsets transmit the full-fidelity data from the front-facing sensors into the VR environment.
- ✓ **While the adoption of VR workspaces is small**, it's worth considering both from an organisational perspective and a personal privacy perspective what information we're broadcasting to all others in the VR environment.



Backtrace in Time: Revealing Attackers' Sleep Patterns and Days Off in RDP Brute-Force Attacks with Calendar Heatmaps

Author:
Andréanne Bergeron

 [Code](#)

 [Blog](#)

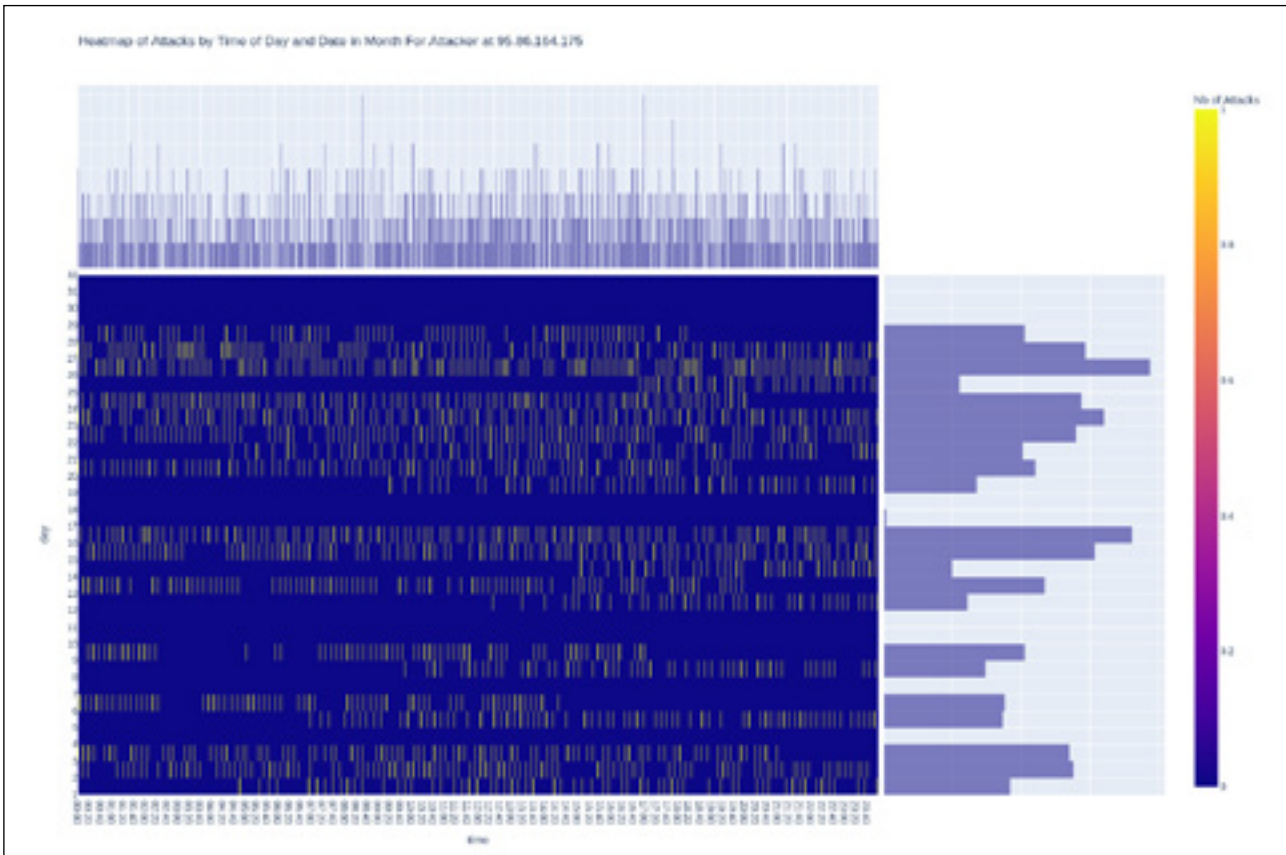
 [Video](#)

This researcher set up Windows RDP (remote desktop protocol) honeypots and performed analysis on the automated attacks. What emerged was a series of subsets in the data that showed different attackers and their respective behaviours. One subset spread out the attacks over time, trying to lessen detection. This group also appeared to stop the automated attacks during weekends – possibly indicating a professional operation. Another group paused for 8-9 hours per day, either to sleep, or to attend to a regular job that didn't allow them to continue their attacks. The final analysis was looking over the course of a year to determine if the data supported the oft-heard claim that attackers ramp up their attacks during Western holidays in hopes of catching their targets off-guard. The author concludes that for these untargeted attacks, there was no data showing significant increases to match with popular holidays.

TAKEAWAYS:

- ✔ **It is always interesting** to see the human touches to automated attacks. These attacks were not highly-targeted, and still have the fingerprints of human-on-the-loop. That different groups of attackers could be differentiated highlights how attacker behaviour is hard to fully hide.
- ✔ **It is interesting** to see the same divide between software developers/security engineers developing tools and the DevOps engineers/SREs who are typically the ones implementing automation and orchestration for the tools mirrored in the attack community.

Figure 6. A chart showing the possibility of attacks subsiding during non-working hours/days, suggesting professional attackers.





Taking another look with a fresh perspective

- ✓ *Breaking HTTP Servers, Proxies, and Load Balancers Using the HTTP Garden*
- ✓ *Compiler Backdooring For Beginners*
- ✓ *Revisiting 2017: AI and Security, 7 years later*
- ✓ *Automated Large-Scale Analysis of Cookie Notice Compliance*

*Jefferson Memorial, Washington, DC.
Image by Jacob Torrey (Thinkst).*

Breaking HTTP Servers, Proxies, and Load Balancers Using the HTTP Garden

Authors: Ben Kallus and Prashant Anantharaman

 [Code](#)

 [Video](#)

This work exercised HTTP servers to detect instances where multiple servers treated the same payload differently. HTTP Request Smuggling is an example-attack-class that makes use of this primitive. For example, if a load-balancer parses one or more requests differently from the actual application servers, a variety of attacks become possible. These attacks have been found in a semi-automated fashion when exploring specific targets, but the HTTP Garden presented here takes that a step further, allowing for easy differential analysis of many HTTP servers, proxies, and load-balancers.

With about six months of effort, almost 90 bugs were discovered and reported in existing, and broadly-deployed servers and proxies. While many of them are of little practical risk, many of them, when multiple servers and proxies are composed, result in the ability to bypass ACLs or other defences. The tooling is open-source, and provides an easy way to explore combinations of components, or add new ones.

Figure 7. An example request to bypass an HAProxy ACL using request smuggling from parser differentials. The HAProxy server sees the first and third GET request, whereas the LiteSpeed server sees the first and second.



TAKEAWAYS:

- ✓ **Despite many of the servers** tested here being part of cloud-scale fuzzing and security reviews, these differential bugs will not come to light unless tested in the same way they are composed: in production.
- ✓ **This tooling** helps bring these issues to light more quickly, and prior to production.
- ✓ **Any organisation** deploying heterogeneous services should consider this type of differential testing.

```
[root@13dca30d5ecd /app/payloads] print
'GET / HTTP/1.1\r\nContent-Length: 0200
\r\n\r\nAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAGET /.ssh/id_rsa HTTP/1
1\r\nContent-Length: 56\r\n\r\nAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAGET / HTTP/1.1\r\nHost: h
proxy\r\n\r\n' | nc haproxy 80
```


Compiler Backdooring For Beginners

Author: Marion Marschalek



This research explored the applicability today of Ken Thomson's famous Turing lecture "[Reflections on Trusting Trust](#)". The lecture, given in 1984, explored the possibility of backdooring a compiler to inject a backdoor when compiling remote access tools, leaving no trace in the remote access source code. Taking it one step further, he proposed detecting if a compiler was being compiled, and then injecting the malicious subversion there, thus the compiler and remote access software source code would be unchanged.

While a theoretical possibility for many decades, this research explored what such an implementation would look like with today's advanced compilers. Focusing on the LLVM/Clang compiler suite, the author revealed it was quite simple to create a malicious pass library that would look for targeted sites in the code to be modified. A demonstration was provided that showed how a tainted compiler could reverse security patches with known exploits in a web server, thus rendering all future versions of the server vulnerable when compiled.

TAKEAWAYS:

- ✓ **While no new theory was demonstrated**, seeing the (relative) simplicity of a modern implementation that renders software bills-of-materials moot (and can leave systems vulnerable) is important.
- ✓ **Supply-chain attacks**, such as those seen in SolarWinds, show that attacking the build process and the surrounding CI/CD pipeline can have far-reaching consequences.
- ✓ **This shows** how relatively easy it is, and how broad the potential threat space could be.

Figure 8. A slide depicting the steps performed to backdoor nginx via Clang.



So, about that backdoor:

- Inspired by tutorial of Andrzej Warzyński (llvm-tutor)
- Create a module pass as a plugin for new pass manager
- Register pass using PassBuilder's registerPipelineStartEPCallback
- Find module src/core/nginx.c
- Insert declaration of libc's system function
- Insert constant string of reverse shell command
- Iterate module's functions, find main
- Use IRBuilder to create call to system with reverse shell argument

Revisiting 2017: AI and Security, 7 years later

Author: Thomas Dullien



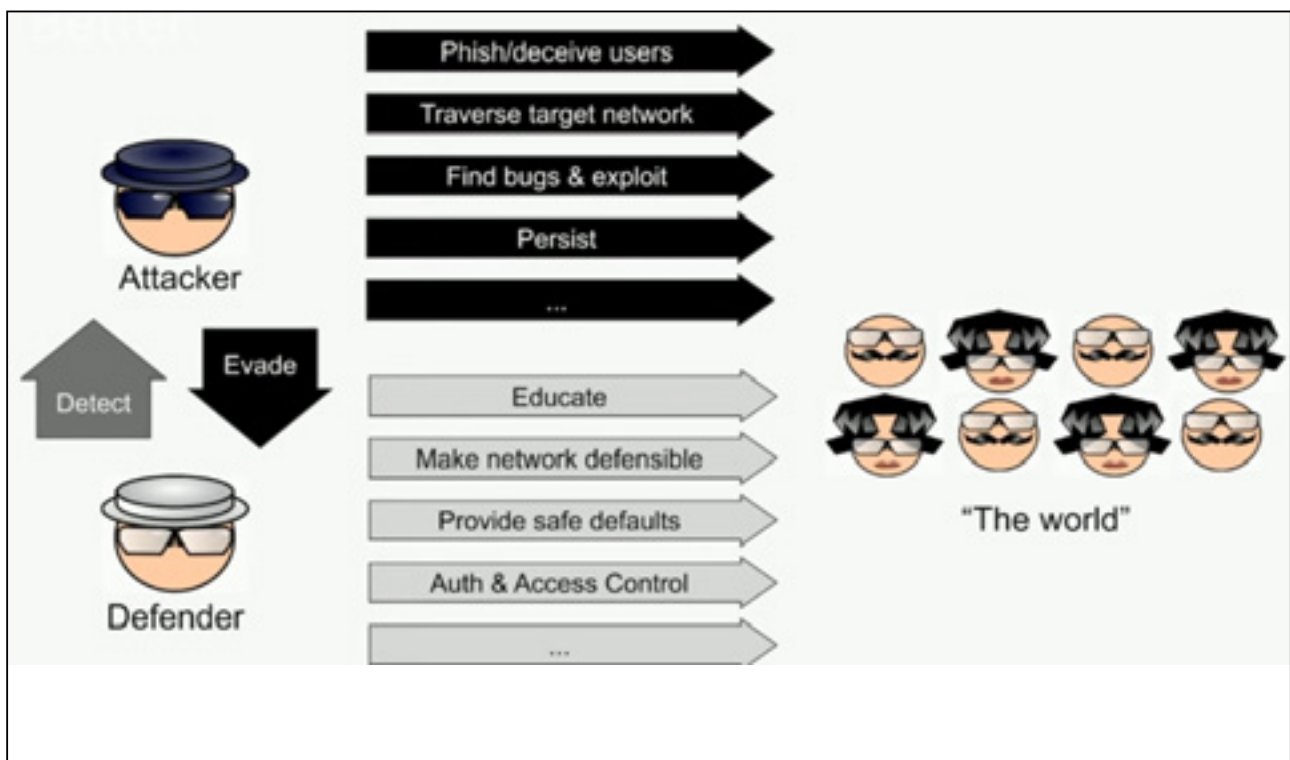
Video

This keynote revisited the world of AI and security after giving a similar, predictive talk seven years prior. The speaker compared his predictions with how events really played out, and then offered more insights into how security and AI can coexist today and into the future. The main incorrect prediction was that 2018 would be the peak of the deep learning and AI hype; LLMs have brought it to a whole new level. The author also looks at why many past applications of ML to security haven't borne the game-changing improvements promised. His contention: that security is an adversarial game, not one that follows stochastic processes. This dynamism in the distribution makes it very difficult to extract signals from the noise as attackers constantly adapt.

TAKEAWAYS:

- ✓ **Stepping back to understand** the distribution you are measuring is crucial to ensuring any ML application will work over time. As shown in the figure, too often defenders imagine themselves directly clashing with attackers, when in fact there are abstractions and environments where both the attackers and defenders work to influence.
- ✓ **The author's notes** about generative AI are astute and he has a long history of solid thinking in this space.
- ✓ **There was a watershed moment** with the release of ChatGPT, but how these new LLMs can actually be used is still very much an open question.

Figure 9. A high-level figure of the world and how attackers and defenders influence it. The author highlights that the majority of AI-based defensive tools aim to detect the attacker, but the distribution of their behaviours changes adversarially.



Automated Large-Scale Analysis of Cookie Notice Compliance

Authors: Ahmed Bouhoula, Karel Kubicek, Amit Zac, Carlos Cotrini, and David Basin



[Paper](#)



[Code](#)

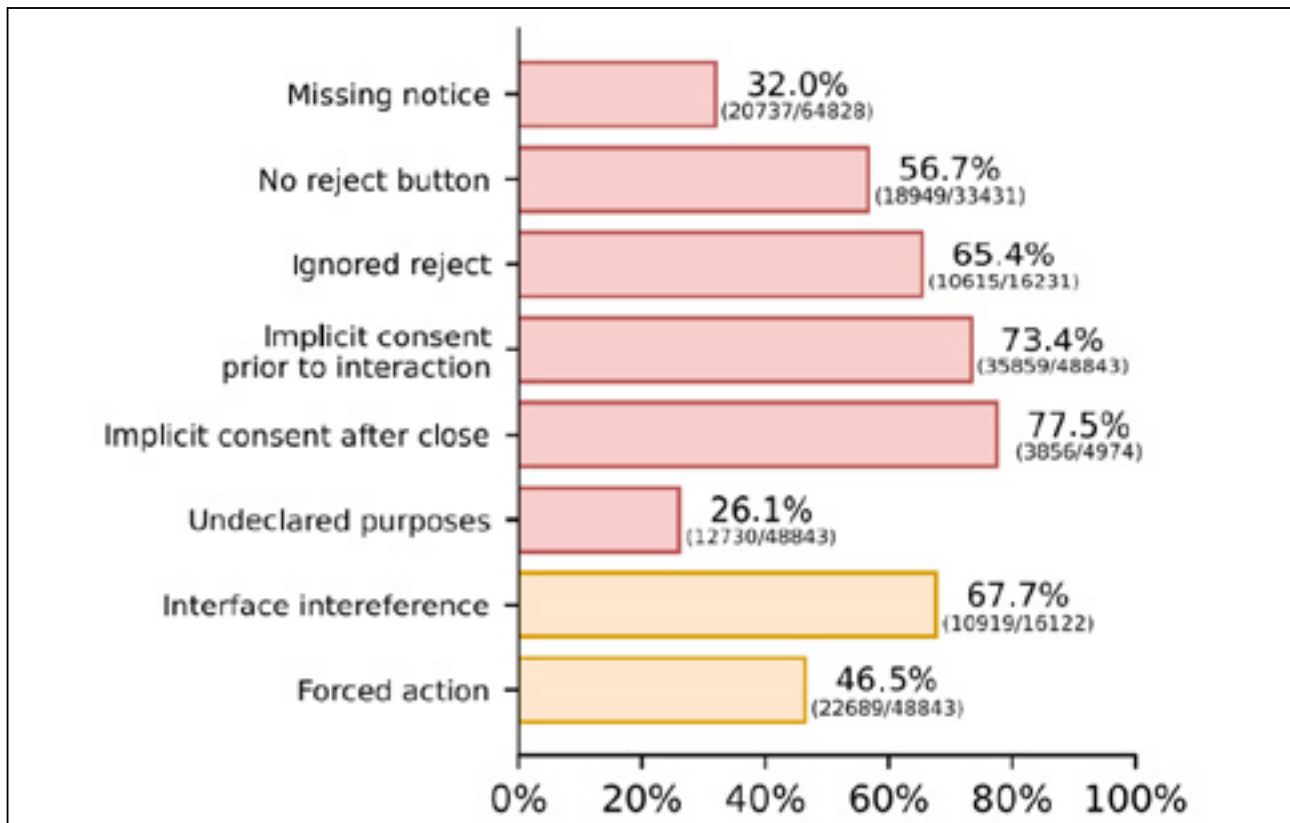
This research explored the adherence to the European Union's privacy regulation: GDPR. By training natural language processing algorithms to understand the privacy and cookie modals, the toolchain could automatically interact with popular pages, and classify the modal's text. By repeatedly visiting the selected site (from within the EU), the tooling could monitor how different selections (e.g., Reject All, Accept All, Only Necessary, etc.) changed the corresponding cookies delivered to the browser. These browser cookies were then analysed to determine if they served a tracking or marketing purpose, and if such cookies had been accepted.

The research discovered that over 90% of the top ~100k sites either were in direct violation of the GDPR, or implemented a so-called Dark Pattern that tried to influence users to accept tracking cookies. ~67% of visited sites continued to set cookies that could be used for tracking and marketing even after a Reject All button was selected.

TAKEAWAYS:

- ✓ **The scale of violations** is truly shocking, and at the same time unsurprising. Dark patterns show up everywhere, but their deployment suggests that they do work.
- ✓ **It's important to consider** how users will behave whenever new security processes are rolled out (and how they may be abused). There is much that can be learned from these techniques to improve security outcomes for users.
- ✓ **The scale of GDPR**, and the complexities surrounding which organisations and users it applies to, lends to shifting the bottleneck to enforcement. Many smaller sites (even in the top 100,000 of visited sites) will likely not expend many resources on compliance, and many larger organisations are willing to handle the ramifications as they come, or treat it as the cost of doing business in the EU.

Figure 10. A chart showing the percentages of websites (browsed from the EU) exhibiting GDPR non-compliance or dark-pattern behaviours.



Turning Windows into doors

- ✓ *LSA Whisperer*
- ✓ *Wishing: Webhook Phishing in Teams*
- ✓ *Misconfiguration Manager: Overlooked and Overprivileged*
- ✓ *Smoke and Mirrors: How to hide in Microsoft Azure*

*A tea plantation in Nyeri, Kenya.
Image by Paul Gichuki (Thinkst)*

LSA Whisperer

Author: Evan
McBroom

 [Slides](#)

 [Blog](#)

 [Code](#)

This research examined the Windows Local Security Authority (LSA) to identify techniques to extract authentication artefacts by using sanctioned APIs (instead of injection or manipulation). The LSA Whisperer project focuses on interacting with Authentication Packages (AP), using their individual message protocols. APs are Security Support Provider (SSP) DLLs that LSA loads to implement a specific authentication logic design. The researcher identified and documented several previously undocumented providers and developed an interface to interact with them. The research reveals that the credentials an attacker needs to accomplish their objectives on a Windows attack can be achieved without accessing LSASS's memory. Using the appropriate system calls, you can get what you want by querying LSA.

TAKEAWAYS:

- ✓ **Attackers will continue to focus** on authentication and credential material. Targeting LSA in this new way helps attackers continue to maintain access and expand access from on-premise to cloud environments.
- ✓ **LSA Whisperer only uses intended functionality** for Windows, and blocking its package calls from succeeding would prevent normal Windows authentication processes from succeeding. Just as attacks move to Living Off the Land to evade detection, we'll likely see continued exploration of built in functionality. Bugs get patched, features endure.

Figure 11. A chart showing the types of authentication providers.

Dll	Common Name	SP	AP	RPC ID	RPC Authn
cloudap	Cloud AP	OAuth 2.0	✓	36	CLOUD_AP
credssp	Credential Delegation SSP	TLS+SPNEGO	—		
kerberos	Kerberos	Kerberos	✓	16	GSS_KERBEROS
livessp	Live SSP	?	✓	32	LIVE_SSP
msapsspc	DPA Client	RPA	—	17	DPA
msnsspc	MSN Client	NTLM	—	18	MSN
msv1_0	Microsoft Authentication Package v1.0	NTLM	✓	10	WINNT
negoexts	Negotiate Extender	NEGOEX	✓	30	NEGO_EXTENDER
negotiate	Negotiate	SPNEGO	✓	9	GSS_NEGOTIATE
pku2u	Public Key User to User	PKU2U	✓	31	NEGO_PKU2U
schannel	Secure Channel	SSL/TLS	✓	14	GSS_SCHANNEL
tspkg	Terminal Services Package		✓	22	?
wdigest	Windows Digest	Digest Access	✓	21	DIGEST

Wishing: Webhook Phishing in Teams

Author: Matthew Eidelberg



Blog



Code

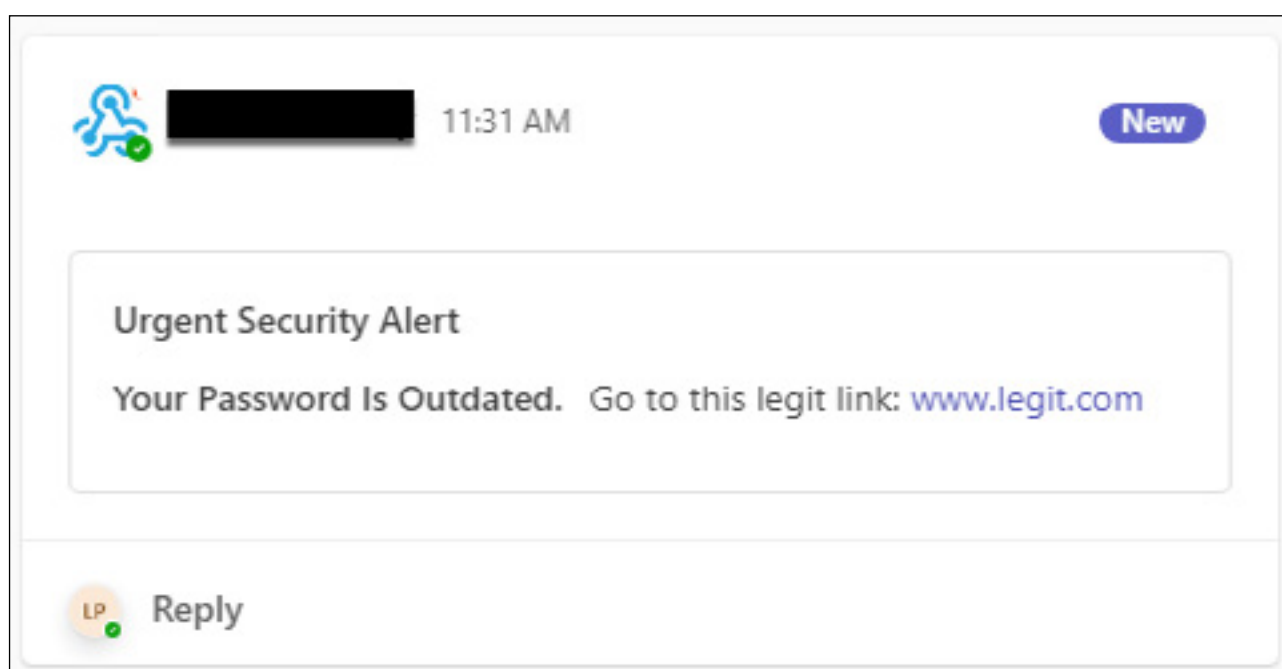
This blog post walks through abusing webhook and email connectors in Microsoft Teams to phish others in an organisation through a channel that looks more official. Any user who can access a Teams channel can configure its integrations. Microsoft does not allow for more fine-grained scoping of permissions for adding webhooks or email addresses. With a low-privileged user authentication token, the provided tooling and techniques can be used to create unauthenticated webhooks that post to Teams channels as an official-looking connector. Additionally, it is possible to set up an email address that forwards to the channel, another possible tactic for social engineering.

The process by which the author is able to vend tokens for one service, change it for another token scope, and change the cookie names, offers a peek into the complexity of Azure authorisation. Seeing how the cookie names reflect previous product names (e.g., Skype vs Teams), offers additional insights into how disparate products have been combined, and how they can be subverted.

TAKEAWAYS:

- ✓ **In addition to the specific attacks** noted against Teams, this blog post showcases the complexity, and attacker opportunities involved with Azure tokens.
- ✓ **Taking low-privileged tokens** scoped for one application and trading them up into a token for another service has been seen in previous attacks. That these techniques continue to bear fruit suggest that authentication and authorisation in the Azure ecosystem is far from solved.

Figure 12. An example of a webhook-initiated phishing attempt sent via Microsoft Teams.



Misconfiguration Manager: Overlooked and Overprivileged

Authors: Duane Michael and Chris Thompson

 [Slides](#)

 [Blog](#)

 [Code](#)

Figure 13.
Misconfiguration Manager
Attack Matrix Overview.



The researchers took a broad look at Microsoft's SCCM (System Center Configuration Manager) and catalogued several misconfigurations. Given the widespread use of SCCM, as well as its privileged access in many networks, it is a ripe target for network privilege escalation and expansion. The SCCM attack surface is vast. Consuming, understanding and actioning all the released research and content is challenging. This research strives to demystify adversary tradecraft so that the community can better protect and defend their environments. This work begins to provide a single place for teams to find resources to test and evaluate their SCCM deployments.

TAKEAWAYS:

- ✔ **Organisations continue** to have over-permissioned tools and resources in their environment. If you use SCCM, it would be wise to review these misconfigurations.
- ✔ **Security and IT teams continue** to inherit technical debt that they did not implement, but have to maintain.

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration
PXE Credentials	App Deployment	App Deployment	Relay to Site Server SMB	App Deployment	PXE Credentials	LDAP Enumeration	App Deployment	CMPIVot		CMPIVot
	Script Deployment	Script Deployment	Relay Client Push Installation	Script Deployment	Policy Request Credentials	SMB Enumeration	Script Deployment			
		ADCS Relay	Relay to DB MSSQL		DPAPI Credentials	HTTP Enumeration	Relay to Site Server SMB			
		LDAP Relay	Relay to DB SMB		Legacy Credentials	CMPIVot	Relay Client Push Installation			
			Relay to ADCS				Relay to DB MSSQL			
			Relay to AdminService		Site Database Credentials		Relay to DB SMB			
			Relay CAS to Child				Relay CAS to Child			
			Relay to SMS Provider SMB				Relay to AdminService			
			Relay between HA				Relay to SMS Provider SMB			

Smoke and Mirrors: How to hide in Microsoft Azure

Authors: Aled Mehta
and Christian
Philipov



Video

The researchers were able to validate that Microsoft Graph API activity logs are purely for calls against the Microsoft Graph API, while the audit logs mostly capture state-changing actions. They also discovered ways to perform enumeration activities where nothing is logged. So, by identifying various legacy APIs along with corresponding built-in Microsoft client OAuth applications, they were able to bypass logging in Azure.

Once “silent” enumeration was performed, a privilege escalation attack was demonstrated through the use of integrations between Microsoft ML services and the Azure SQL database. The API call made by a low-permissioned user to the ML service returns the service principal credentials used to access the SQL service. If that service principal was misconfigured with any additional permissions, it would be possible to login to Azure with that identity (gaining further access into the tenant).

TAKEAWAYS:

- ✓ **It will be imperative** that organisations continue to pressure Microsoft to give their teams the data they deem relevant.
- ✓ **In this case an entire class of enumeration attacks** are simply not logged, leading to defenders only detecting adversaries after they had mapped significant portions of their Azure environment.
- ✓ **This is another example** of Shared Responsibility gone wrong. What defenders want to be able to hunt in telemetry, may not be in the cloud provider’s interest to enable or capture. This leaves defenders blind, or having to pay extra for logs that should’ve been free/accessible to begin with.

Figure 14. A list of what information is logged by the GraphAPI, none of which is visible when using the legacy APIs.



What is logged?				
User	Request	Response	Processing	Logging
AadTenantId	ApiVersion	ResponseSizeBytes	ClientRequestId	_BilledSize
AppId	IPAddress	ResponseStatusCode	DurationMs	_IsBillable
ClientAuthMethod	RequestMethod		Location	ATContent
IdentityProvider	RequestUri		OperationId	SourceSystem
Roles	UserAgent		RequestId	TenantId*
Scopes			SignInActivityId	Type
ServicePrincipalId			TimeGenerated	
TokenIssuedAt				
UserId				

*this is actually the ID of the Log Analytics workspace

W / T H

Nifty sundries

- ✓ *Backdoor in XZ Utils allows RCE: everything you need to know*
- ✓ *More Money, Fewer FOSS Security Problems? The Data, Such As It Is*
- ✓ *MUDding Around: Hacking for gold in text-based games*
- ✓ *DeGPT: Optimizing Decompiler Output with LLM*

*A farm road outside Kleinmond.
Image by Tom Windell (Thinkst)*

Backdoor in XZ Utils allows RCE: everything you need to know

Authors: Andres Freund, Merav Bar, Amitai Cohen, Danielle Aminov, and Russ Cox

✓ [Disclosure](#)

✓ [Blog](#)

✓ [Timeline](#)

While researching a subtle performance drop, Andres Freund came to the shocking discovery that the latest version of XZ Utils was backdoored in a way that impacted SSH server authentication. XZ Utils is a compression library that is highly efficient, and is thus widely used in the Linux ecosystem (and beyond). After the discovery (and subsequent roll-back of the backdoored versions), many voices in the community unwound an incredible attack performed over the course of multiple years.

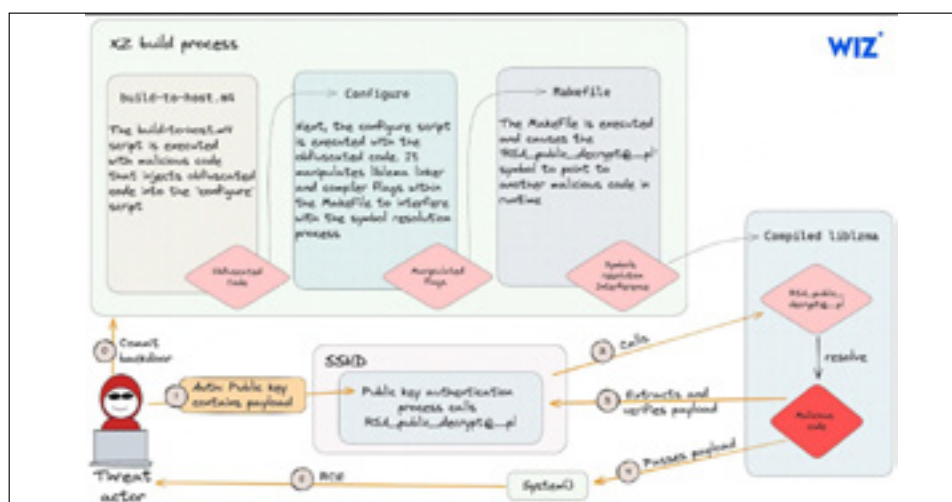
- In 2021, a new community member starts contributing patches to the XZ Utils while another member complains to the volunteer maintainer and project founder about how their delays in accepting patches is putting the project in jeopardy.
- Months later, the first community member is added to the group of project maintainers, and continues to commit improvements.
- In early 2024, they add a binary test file that gets injected into the build scripts.
- Once built, the modified XZ library updates the `RSA_public_decrypt` function used as part of the SSH authentication process.
- If an SSH certificate matching certain criteria is presented, the backdoor is activated, either executing the data from the certificate as root, or bypassing authentication.

This change was detected before the newer version of XZ Utils was included in many Linux distributions, limiting the scope of deployment, but there were bleeding edge versions impacted. To date there hasn't been any conclusive attribution of the attackers, and whether the community members calling for their promotion to maintainer were part of the same operation.

TAKEAWAYS:

- ✓ **This case highlights** how sophisticated adversaries can spend significant resources (and time) towards a goal.
- ✓ **It is hard to think about** how an attacker that is willing to contribute for multiple years would not gain the access they desire within any project, open-source or commercial. While the economics of open-source are certainly part of this story, it is not impossible to imagine an engineer joining a commercial vendor and gaining commit access to their products after years of contributions.
- ✓ **While the discovery was lucky**, it showed the power of the open-source community and the security community surrounding it.
- ✓ **A multitude of people** with different backgrounds volunteered their time in analysis, response, etc. Had this been a commercial project, disclosure would have been much more opaque, and there would have been a smaller pool of skilled people to draw on in order to run it to ground.

Figure 15. Wiz's diagram of the XZ backdoor process and how it could be used to gain access to an affected system.



More Money, Fewer FOSS Security Problems? The Data, Such As It Is

Authors: John Speed Meyers, Sara Ann Brackett, and Stewart Scott



In this work, the researchers tried to statistically quantify the impact of funding open-source projects and their security. The last few years have seen more investment in open-source projects, from OSSFuzz to the Open Technology Fund, to grassroots sponsoring of individual projects. While the data was limited, the researchers took the top 1,000 most popular projects on both PyPi and npm, and analysed each for both their funding status and how the project scored on the OpenSSF security scorecard.

The scorecard looks at a project as a whole to try to quantify the presence and maturity of certain procedures that are correlated with security, such as fuzzing, signed releases, if they are actively maintained, etc.

The research did find that there was a statistically significant improvement on the scorecard performance of projects that received funding. While the biggest score difference was if there was a maintainer at all (which is likely a requirement for funding), projects receiving funding were more likely to have automated fuzzing, security policies, and more mature updates and packaging procedures.

TAKEAWAYS:

- ✓ **Caveats aside**, this work does show that there are certain aspects of projects that indicate good security that are more prevalent with funding. While the data doesn't show the causality, or even if projects were well-scoring prior to getting funding, investing in security frameworks and projects seems to improve security-relevant outcomes.
- ✓ **With the XZ backdoor** (discovered after this talk) garnering broad attention on open-source supply chains, there is hope that this data can guide more funding to critically underfunded projects, and improve the data availability into how the funding is allocated.

Figure 16. A table showing statistically significant improvements in OpenSSF security scorecard scores for sponsored or funded open-source projects.

Python- in the Scorecard weeds				
Check Type	Any-None Diff	Tidelift-None	OpenCollective-None	Github Sponsors
Dependency-Update-Tool	0.66	4.03	2.64	0.53
Fuzzing	1.23	1.20	2.80	1.17
License	0.03	0.20	-0.16	0.02
Maintained	1.49	3.83	4.14	1.39
Packaging	0.69	1.60	1.60	0.68
Pinned-Dependencies	-0.34	-0.90	-1.58	-0.27
SAST	0.23	2.00	0.68	0.27
Security-Policy	0.49	3.79	1.99	0.33
Signed-Releases	0.35	0.18	0.62	0.36

MUDding Around: Hacking for gold in text-based games

Author: *Unix-ninja*



Blog

This blog post discusses the steps of elevating privileges that were restricted through tools such as rbash. rbash limits the shell users to only specific executables, and prevents accessing data outside of the configured root path (similar to a chroot jail). The author used a number of obscure shell tricks to bypass restrictions on file access, as well as change the configurations used to prevent further privilege elevation. The specific target in this blog was a limited shell for a text-based game, and the author ultimately found a way to use the game client for final privilege elevation. More generally, the preceding steps would be well worth knowing about to prevent similar attacks on a multi-tenant Linux host.

TAKEAWAYS:

- ✓ **While containerisation has begun to overtake** OS-level multi-tenancy enforcement, using Linux in a multi-user fashion is still common.
- ✓ **This article highlights** a number of rarely-used features that can bypass tools designed for containing low-privilege users and serves as a good reminder that feature creep can impact security when used by a motivated attacker.

DeGPT: Optimizing Decompiler Output with LLM

Authors: Peiwei Hu, Ruigang Liang, and Kai Chen



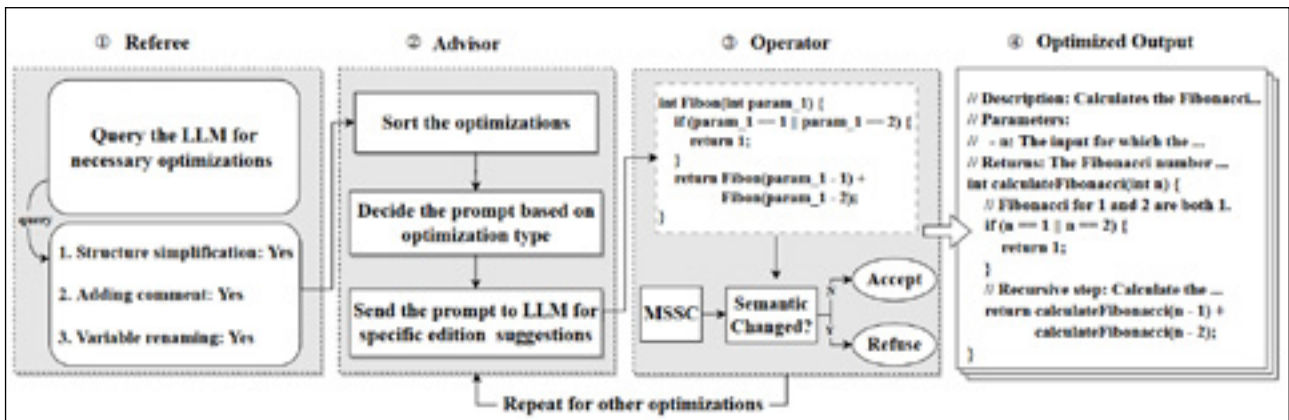
This research explored using LLMs to improve the readability (decreasing the cognitive load needed to understand the output) of decompiler output. Decompilers, which take compiled binaries as input, and output source code, have improved with regards to their ability to be able to recompile the output back to a semantically-similar binary. However, decompiler output, while certainly more understandable than disassembly, is still difficult to read due to a lack of variable names, awkward and non-idiomatic code layout, etc.

This work used multiple LLMs to determine which improvements would best help readability, then generated prompts to edit the code. These edits were then checked to see if the semantics were altered, offering the operator the opportunity to accept or reject the change. Evaluation on the optimised output found a 24% reduction in cognitive load to understand the decompiled code. In 63% of cases, the comments added were correct and added to readability.

TAKEAWAYS:

- ✔ **Compilation and binary distribution** have often been overly-relied on for obfuscation and security.
- ✔ **As these decompilation toolchains** improve both recompilation ability and understandability, there will be nowhere to hide poor security development practices.

Figure 17. High-level diagram of how the three LLMs/components cooperate to improve decompiler output.





A Frangipani tree in Hyderabad, India.
Image by Jacob Torrey (Thinkst)

Conclusions

We started off 2024 with a modest amount of high-quality works, though we fully expect the volume to increase in the coming quarters. In quarters with fewer conferences, we see a number of both blogs and pre-publication papers released, reducing the wait from research to public access.

WE HIGHLIGHTED THREE THEMES FOR THIS QUARTER:

1. Side-channels in unexpected places.
2. Fresh perspectives yielding new insights.
3. Misusing the Microsoft ecosystem while still following the rules.

We're looking forward to seeing what comes next in 2024.

